



R I S O R S A 1 5

Policy AI Interna Estesa

Modello editabile per PMI italiane 5-50 dipendenti

Da "Intelligenza Artificiale in Pratica per PMI" — Alioscia Battaglini

Policy aziendale per l'uso dell'Intelligenza Artificiale

[NOME AZIENDA] — Versione 1.0 — In vigore dal [DATA]

Documento approvato da: [LEGALE RAPPRESENTANTE] · Responsabile attuazione: [NOME RUOLO]

Premessa e ambito di applicazione

La presente Policy regola l'uso degli strumenti di Intelligenza Artificiale generativa (di seguito "AI") all'interno di [NOME AZIENDA]. Si applica a tutti i dipendenti, collaboratori, consulenti esterni che utilizzano AI per attività aziendali, indipendentemente dal contratto di collaborazione.

L'AI viene introdotta in azienda per supportare e amplificare il lavoro delle persone, non per sostituirle. La responsabilità di ogni contenuto, decisione, azione resta sempre umana.

Sezione 1 — Strumenti AI ufficialmente adottati

L'azienda ha adottato i seguenti strumenti AI per uso lavorativo. L'uso di altri strumenti per scopi aziendali deve essere preventivamente autorizzato dal Responsabile AI.

- ▶ **ChatGPT Team / Plus** — per attività di scrittura, analisi documenti, supporto operativo generale
- ▶ **Claude Pro / Team** — per attività di scrittura raffinata, analisi documenti lunghi, ragionamento complesso
- ▶ **NotebookLM** (versione gratuita) — per interrogare documenti aziendali interni
- ▶ **[Eventuali altri strumenti specifici della tua azienda]**

Sezione 2 — Dati che NON possono essere inseriti negli strumenti AI pubblici

I seguenti dati possono essere usati esclusivamente sui piani aziendali approvati (Team/Enterprise con contratto di trattamento dati conforme GDPR). Non vanno mai inseriti in chat AI pubbliche, gratuite o di terze parti non autorizzate.

Categorie di dati protetti

- ▶ **Dati personali identificativi** di clienti, fornitori, dipendenti (nomi, email, telefoni, indirizzi, codici fiscali)
- ▶ **Listini prezzi confidenziali** e condizioni commerciali specifiche
- ▶ **Contratti firmati** e accordi di riservatezza (NDA)
- ▶ **Categorie particolari di dati personali** (art. 9 GDPR): dati sanitari, biometrici, religiosi, opinioni politiche, ecc.
- ▶ **Password, credenziali, chiavi API**

- ▶ **Segreti industriali**, formule, processi protetti, brevetti in fase di registrazione
- ▶ **Dati finanziari sensibili** (saldi bancari, IBAN, dati di pagamento)

Casi consentiti

I dati elencati sopra possono essere usati su account aziendali Team/Enterprise approvati, dove l'azienda ha un contratto di trattamento dati conforme. In ogni caso, **anonimizzare o pseudonimizzare** i dati sensibili quando non strettamente necessari per il task.

Sezione 3 — Attivazione di nuovi abbonamenti AI

Solo il Responsabile AI o l'Amministratore Delegato possono attivare nuovi abbonamenti AI a nome dell'azienda. È vietato l'uso di account personali per scopi aziendali, anche su base temporanea. La motivazione: gli account personali non hanno protezioni dati aziendali e i loro contenuti possono essere usati per addestramento dei modelli.

Sezione 4 — Rilettura e responsabilità sui contenuti AI

Tutti i contenuti generati con AI che vengono inviati esternamente (clienti, fornitori, partner, autorità) o pubblicati pubblicamente devono essere riletti e approvati da una persona qualificata prima dell'invio o pubblicazione.

La responsabilità dei contenuti rimane sempre umana. L'AI è uno strumento di supporto, non un autore autonomo. Errori nei contenuti generati con AI sono imputabili alla persona che li ha approvati e inviati.

Per i contenuti interni (note, riassunti, draft di lavoro che non escono dall'azienda), è ammesso un livello di controllo più leggero, ma la persona resta responsabile della correttezza dei contenuti che usa per le proprie decisioni.

Sezione 5 — Gestione errori AI (allucinazioni)

L'AI può generare informazioni errate o inventate ("allucinazioni"), in particolare su numeri, citazioni, fonti, dati specifici. Per questo:

- ▶ Tutti i numeri, dati statistici, citazioni, riferimenti normativi prodotti dall'AI vanno verificati con fonti indipendenti prima di essere usati esternamente
- ▶ In caso di rilevamento di errore in un contenuto già usato esternamente, notificare immediatamente il Responsabile AI
- ▶ Documentare il caso (cosa è successo, chi era coinvolto, quando, conseguenze)
- ▶ Adottare misure correttive (rettifica al destinatario, comunicazione cliente, ecc.)
- ▶ Aggiornare le procedure interne se l'errore è ricorrente o potenzialmente grave

Sezione 6 — Trasparenza verso clienti, fornitori, autorità

L'uso dell'AI per supportare la nostra attività è dichiarato nella nostra informativa privacy aziendale ([LINK O RIFERIMENTO]). Per contenuti specifici dove la trasparenza è particolarmente rilevante (testimonianze, recensioni, contenuti che imitano persone reali), va sempre dichiarato esplicitamente l'uso dell'AI.

Sezione 7 — Sicurezza tecnica

Tutti gli account AI aziendali devono avere:

- ▶ **Autenticazione a due fattori (MFA)** attiva e obbligatoria
- ▶ **Accesso individuale** (no account condivisi tra colleghi)
- ▶ Quando possibile, **Single Sign-On (SSO)** integrato con i sistemi aziendali
- ▶ **Password gestite tramite password manager aziendale** ([STRUMENTO]), mai condivise via mail o chat
- ▶ **Disattivazione immediata** dell'account quando una persona esce dall'azienda

Sezione 8 — Formazione obbligatoria

Ogni dipendente che riceve accesso a uno strumento AI aziendale deve completare prima un breve modulo formativo aziendale (durata: 2-4 ore) che copre: principi base AI, pratica sui prompt, regole di sicurezza, simulazione casi pratici. La formazione viene aggiornata almeno annualmente.

Sezione 9 — Monitoraggio e audit

Il Responsabile AI effettua almeno trimestralmente:

- ▶ Verifica degli account attivi e dei costi
- ▶ Verifica accessi (chi entra, chi non dovrebbe più entrare)
- ▶ Spot check su contenuti generati con AI
- ▶ Aggiornamento policy se le normative o gli strumenti adottati cambiano

Sezione 10 — Sanzioni in caso di violazione

La violazione delle regole della presente Policy può comportare azioni disciplinari secondo quanto previsto dal CCNL applicato e dal Codice Disciplinare aziendale, fino al licenziamento per giusta causa nei casi più gravi (es. inserimento intenzionale di dati riservati in account pubblici causando danno aziendale).

Sezione 11 — Conformità normativa di riferimento

- ▶ **Regolamento UE 2016/679 (GDPR)**
- ▶ **Regolamento UE 2024/1689 (AI Act)**
- ▶ **Legge italiana 132/2025** sull'AI
- ▶ **Statuto dei Lavoratori** (legge 300/1970) per gli aspetti che riguardano monitoraggio dipendenti

Allegato A — Modulo accettazione policy (per dipendenti)

Il sottoscritto/a _____ dichiara di aver letto e compreso la Policy AI Interna di [NOME AZIENDA] versione 1.0 in vigore dal [DATA] e si impegna a rispettarla pienamente.

Data: _____ Luogo: _____ Firma: _____

Allegato B — Schema responsabilità (RACI semplificato)

Responsabile AI: [NOME] — definisce strumenti, gestisce accessi, fa audit, aggiorna policy

AI Owner per area: [LISTA per area] — applicano AI nei loro processi, mantengono prompt e GPT

Tutti i dipendenti che usano AI: rispettano la policy, segnalano errori, completano formazione

Amministratore Delegato: approva acquisti AI, valida policy, interviene in caso di violazione grave

Documento da personalizzare per la propria realtà aziendale. Non costituisce parere legale: per applicazioni con obblighi specifici (settori regolati, decisioni AI ad alto rischio), consultare il proprio consulente legale.

© 2026 Alioscia Battaglini · AIOsha · info@aiosha.it